

[NOME_FINAL_DO_PRODUTO]

[NOME_DA_EMPRESA]

Diretrizes de Segurança da Informação

Versao:	1.0
Data:	Maio de 2026
Classificacao:	Interno - Confidencial
Empresa:	[NOME_DA_EMPRESA]

Diretrizes de Segurança da Informação

[NOME_DA_EMPRESA]

Versão: 1.0 · Maio de 2026

Classificação: Interno — Restrito

Nota: Este documento estabelece diretrizes de segurança como referência organizacional interna. A implementação técnica e conformidade regulatória formal devem ser validadas por especialistas em segurança da informação e assessoria jurídica qualificada.

Sumário

- Princípios de Segurança
- Controle de Acesso
- Segurança de Dados
- Segurança de Infraestrutura
- Gestão de Vulnerabilidades
- Monitoramento e Auditoria
- Segurança em Desenvolvimento
- Responsabilidades

1. Princípios de Segurança

A [NOME_DA_EMPRESA] adota a segurança como atributo arquitetural — não como camada adicionada posteriormente. Os princípios que orientam nossas práticas de segurança:

Mínimo privilégio: cada usuário e sistema tem acesso apenas ao estritamente necessário para suas funções.

Defesa em profundidade: múltiplas camadas de controle, de forma que a falha de uma não comprometa todo o sistema.

Segurança por design: requisitos de segurança considerados desde o início do desenvolvimento de cada funcionalidade.

Visibilidade e rastreabilidade: ações relevantes são registradas em logs auditáveis.

Responsabilidade compartilhada: segurança é responsabilidade de toda a equipe, com papéis específicos

definidos para as áreas técnicas.

2. Controle de Acesso

Autenticação

- Autenticação obrigatória para todos os acessos à plataforma
- Senhas com requisito mínimo de complexidade definido
- Autenticação multifator (MFA) para administradores e acessos privilegiados
- Tokens de sessão com expiração configurada
- Bloqueio automático após tentativas de login malsucedidas

Autorização

- Modelo de controle de acesso baseado em papéis (RBAC)
- Perfis de acesso definidos: Administrador, Profissional de Saúde, Recepção, Gestor, Auditoria
- Segregação de funções: usuários não acumulam permissões incompatíveis
- Revisão periódica de acessos: trimestral

Gestão de Acessos Administrativos

- Acessos de administrador de sistema limitados ao mínimo necessário
 - Credenciais administrativas armazenadas em cofre de senhas
 - Rotação obrigatória de credenciais administrativas a cada 90 dias
 - Acesso privilegiado registrado em log de auditoria
-

3. Segurança de Dados

Dados em Trânsito

- Toda comunicação cifrada com TLS 1.2 ou superior
- Certificados SSL/TLS válidos e renovados automaticamente
- HSTS (HTTP Strict Transport Security) habilitado

Dados em Repouso

- Criptografia de banco de dados para dados sensíveis (dados de saúde, documentos pessoais)
- Backups cifrados
- Chaves de criptografia gerenciadas de forma segura e separada dos dados

Classificação de Dados

Classificação	Descrição	Exemplos
Altamente Sensível	Dados de saúde, prontuários, diagnósticos	Prontuário eletrônico, prescrições, laudos
Sensível	Dados pessoais identificáveis	Nome, CPF, endereço, contato
Interno	Dados operacionais não pessoais	Relatórios gerenciais, logs de sistema
Público	Informações sem restrição	Documentos institucionais públicos

Retenção e Descarte

- Dados de saúde retidos conforme exigência legal (CFM, MS)
- Dados desnecessários descartados de forma segura (sobreescrita ou destruição)
- Política de retenção documentada e revisada anualmente

4. Segurança de Infraestrutura

Ambientes

- Separação estrita entre ambientes: produção, homologação e desenvolvimento
- Dados reais de produção não utilizados em ambientes de desenvolvimento
- Acesso à produção restrito ao Diretor de Infraestrutura e CEO

Rede

- Segmentação de rede com firewalls configurados
- Portas e serviços expostos restringidos ao mínimo necessário
- VPN para acesso administrativo remoto
- Bloqueio de IPs suspeitos e proteção contra DDoS básica

Cloud

- Infraestrutura em provedor cloud com certificação SOC 2 / ISO 27001
- Configurações de segurança do provedor cloud auditadas periodicamente
- Buckets de armazenamento não públicos por padrão
- Logs de acesso ao cloud habilitados

Backup e Continuidade

- Backup diário dos dados de produção
- Testes de restauração mensais
- RTO (Recovery Time Objective): 4 horas para incidente crítico
- RPO (Recovery Point Objective): 24 horas (último backup)

5. Gestão de Vulnerabilidades

- Atualizações de segurança de dependências aplicadas em até 7 dias para críticas
- Varredura de vulnerabilidades em código antes de deploys relevantes
- Processo de reporte de vulnerabilidades externas: [EMAIL_PRIVACIDADE]
- Política de responsible disclosure para pesquisadores externos

6. Monitoramento e Auditoria

- Logs de acesso e operações sensíveis retidos por mínimo de 12 meses
- Alertas automáticos para eventos anômalos (tentativas de invasão, acessos fora do padrão)
- Revisão semanal de alertas de segurança pelo Diretor de Infraestrutura
- Auditoria formal de segurança anual

7. Segurança em Desenvolvimento

- Code review obrigatório para mudanças em funcionalidades críticas
- Análise de segurança em funcionalidades que tratam dados sensíveis
- Não armazenamento de credenciais em código ou repositórios
- Dependências de terceiros avaliadas antes da adoção
- Princípio de segurança por design em novos módulos

8. Responsabilidades

Responsabilidade	Responsável
Política de segurança e conformidade	CEO
Implementação de controles técnicos	Diretor de Infraestrutura
Segurança em desenvolvimento	CEO (arquitetura)
Resposta a incidentes de segurança	Infraestrutura + CEO
Treinamento de segurança da equipe	CEO
Encarregado de Dados (DPO)	A designar / CEO provisoriamente